

LAPORAN PRAKTIKUM PENJAMINAN DAN KEAMANAN INFORMASI

*Analisis Kepatuhan ISO/IEC 27001:2013 Berdasarkan Hasil Scan Acunetix pada
<https://id.quora.com/>*



Disusun Oleh :

Rizki Slamet Aryanto

2402070

PROGRAM STUDI D3 TEKNIK INFORMATIKA

POLITEKNIK PURBAYA

2026

BAB I — PENDAHULUAN

1.1 Latar Belakang

Keamanan informasi menjadi aspek krusial bagi organisasi yang mengelola data dan layanan digital. ISO/IEC 27001:2013 merupakan standar internasional Information Security Management System (ISMS) yang dipublikasikan oleh International Organization for Standardization (ISO) bersama International Electrotechnical Commission (IEC) pada bulan September 2013. Standar ini menyediakan model untuk membangun, menerapkan, mengoperasikan, memantau, meninjau, memelihara, dan meningkatkan sistem manajemen keamanan informasi pada suatu organisasi.

Untuk mengevaluasi sejauh mana suatu layanan berbasis web memenuhi kontrol-kontrol yang dipersyaratkan oleh ISO/IEC 27001:2013, dapat digunakan bantuan tools vulnerability scanner. Salah satu tools yang umum digunakan adalah Acunetix, yang mampu melakukan pemindaian otomatis terhadap suatu aplikasi web dan memetakan temuan kerentanannya ke berbagai klausul kontrol ISO/IEC 27001:2013 dalam bentuk compliance report.

1.2 Tujuan

- Memahami penerapan klausul-klausul ISO/IEC 27001:2013 pada konteks keamanan aplikasi web.
- Menganalisis hasil compliance report yang dihasilkan oleh Acunetix terhadap target uji.
- Mengevaluasi tingkat kepatuhan teknis target terhadap kontrol-kontrol ISO/IEC 27001:2013 yang relevan.

1.3 Ruang Lingkup

Praktikum ini menggunakan hasil pemindaian Acunetix terhadap target <https://id.quora.com/> yang dilakukan pada tanggal 14 April 2026 pukul 11:30:40 dengan profil Full Scan dan durasi pemindaian selama 1 menit 9 detik. Laporan ini membahas 27 klausul kontrol ISO/IEC 27001:2013 yang tercakup dalam compliance report tersebut.

BAB II — LANDASAN TEORI

2.1 ISO/IEC 27001:2013

ISO/IEC 27001:2013 berjudul lengkap "Information technology — Security techniques — Information security management systems — Requirements". Standar ini menetapkan persyaratan bagi organisasi dalam membangun, menerapkan, memelihara, dan terus meningkatkan sistem manajemen keamanan informasi (ISMS), termasuk penilaian dan penanganan risiko keamanan informasi yang disesuaikan dengan kebutuhan organisasi.

2.2 Acunetix

Acunetix adalah web vulnerability scanner yang digunakan untuk mengidentifikasi kerentanan keamanan pada aplikasi web, seperti SQL Injection, Cross-Site Scripting (XSS), kesalahan konfigurasi server, dan berbagai celah keamanan lainnya. Salah satu fitur Acunetix adalah compliance report, yang memetakan hasil pemindaian teknis ke dalam kerangka kontrol standar keamanan informasi, salah satunya ISO/IEC 27001:2013, sehingga hasil pemindaian dapat dibaca dalam konteks kepatuhan standar tersebut.

BAB III — METODOLOGI

3.1 Profil Pemindaian

URL Target	https://id.quora.com/
Tanggal Scan	14 April 2026, 11:30:40
Durasi	1 menit, 9 detik
Profil Scan	Full Scan
Tools	Acunetix Web Vulnerability Scanner
Standar Referensi	ISO/IEC 27001:2013

3.2 Prosedur Pengujian

Pengujian dilakukan secara otomatis oleh Acunetix dengan melakukan crawling terhadap target, kemudian menjalankan serangkaian pengujian kerentanan sesuai profil Full Scan. Setiap temuan kerentanan (jika ada) selanjutnya dipetakan secara otomatis oleh Acunetix ke klausul-klausul kontrol ISO/IEC 27001:2013 yang relevan, sehingga menghasilkan compliance report yang menunjukkan status setiap klausul.

BAB IV — HASIL DAN ANALISIS

4.1 Ringkasan Kepatuhan (Compliance at a Glance)

Tabel berikut merangkum status kepatuhan seluruh 27 klausul kontrol ISO/IEC 27001:2013 yang tercakup dalam compliance report. Hasil pemindaian menunjukkan bahwa seluruh klausul berstatus "Tidak ada alert", yang berarti Acunetix tidak menemukan kerentanan teknis yang dapat dipetakan ke masing-masing klausul tersebut selama sesi pemindaian.

No	Klausul	Kontrol	Status
1	8.1.1	Inventory of assets	Tidak ada alert

No	Klausul	Kontrol	Status
2	8.2.3	Handling of assets	Tidak ada alert
3	9.1.2	Access to networks and network services	Tidak ada alert
4	9.2.3	Management of privileged access rights	Tidak ada alert
5	9.2.4	Management of secret authentication information of users	Tidak ada alert
6	9.3.1	Use of secret authentication information	Tidak ada alert
7	9.4.1	Information access restriction	Tidak ada alert
8	9.4.2	Secure log-on procedures	Tidak ada alert
9	9.4.3	Password management system	Tidak ada alert
10	9.4.4	Use of privileged utility programs	Tidak ada alert
11	9.4.5	Access control to program source code	Tidak ada alert
12	12.1.4	Separation of development, testing and operational environments	Tidak ada alert
13	12.2.1	Controls against malware	Tidak ada alert
14	12.4.2	Protection of log information	Tidak ada alert

No	Klausul	Kontrol	Status
15	12.4.3	Administrator and operator logs	Tidak ada alert
16	12.5.1	Installation of software on operational systems	Tidak ada alert
17	13.1.1	Security of network services	Tidak ada alert
18	13.2.1	Information transfer policies and procedures	Tidak ada alert
19	13.2.3	Electronic messaging	Tidak ada alert
20	14.1.2	Securing application services on public networks	Tidak ada alert
21	14.1.3	Protecting application services transactions	Tidak ada alert
22	14.2.1	Secure development policy	Tidak ada alert
23	14.3.1	Protection of test data	Tidak ada alert
24	17.2.1	Availability of information processing facilities	Tidak ada alert
25	18.1.3	Protection of records	Tidak ada alert
26	18.1.4	Privacy and protection of personally identifiable information	Tidak ada alert
27	18.1.5	Regulation of cryptographic controls	Tidak ada alert

4.2 Detail per Kelompok Kontrol

A. Manajemen Aset

(8.1.1) Inventory of assets

Aset yang terkait informasi dan fasilitas pemrosesan informasi harus diidentifikasi dan dibuat daftar inventarisnya.

Hasil scan: Tidak ada alert pada kategori ini.

(8.2.3) Handling of assets

Prosedur penanganan aset harus dikembangkan sesuai skema klasifikasi informasi organisasi.

Hasil scan: Tidak ada alert pada kategori ini.

B. Kontrol Akses

(9.1.2) Access to networks and network services

Pengguna hanya diberi akses jaringan dan layanan jaringan yang telah diotorisasi.

Hasil scan: Tidak ada alert pada kategori ini.

(9.2.3) Management of privileged access rights

Alokasi dan penggunaan hak akses istimewa harus dibatasi dan dikendalikan.

Hasil scan: Tidak ada alert pada kategori ini.

(9.2.4) Management of secret authentication information of users

Alokasi informasi otentikasi rahasia dikendalikan melalui proses manajemen formal.

Hasil scan: Tidak ada alert pada kategori ini.

(9.3.1) Use of secret authentication information

Pengguna wajib mengikuti praktik organisasi dalam penggunaan informasi otentikasi rahasia.

Hasil scan: Tidak ada alert pada kategori ini.

(9.4.1) Information access restriction

Akses ke informasi dan fungsi sistem aplikasi dibatasi sesuai kebijakan kontrol akses.

Hasil scan: Tidak ada alert pada kategori ini.

(9.4.2) Secure log-on procedures

Akses ke sistem dan aplikasi dikendalikan melalui prosedur log-on yang aman.

Hasil scan: Tidak ada alert pada kategori ini.

(9.4.3) Password management system

Sistem manajemen password harus interaktif dan memastikan kualitas password.

Hasil scan: Tidak ada alert pada kategori ini.

(9.4.4) Use of privileged utility programs

Penggunaan program utilitas yang dapat mengesampingkan kontrol sistem harus dibatasi.

Hasil scan: Tidak ada alert pada kategori ini.

(9.4.5) Access control to program source code

Akses ke kode sumber program harus dibatasi.

Hasil scan: Tidak ada alert pada kategori ini.

C. Keamanan Operasional

(12.1.4) Separation of development, testing and operational environments

Lingkungan pengembangan, pengujian, dan operasional harus dipisahkan.

Hasil scan: Tidak ada alert pada kategori ini.

(12.2.1) Controls against malware

Kontrol deteksi, pencegahan, dan pemulihan terhadap malware harus diterapkan.

Hasil scan: Tidak ada alert pada kategori ini.

(12.4.2) Protection of log information

Fasilitas dan informasi log harus dilindungi dari manipulasi dan akses tidak sah.

Hasil scan: Tidak ada alert pada kategori ini.

(12.4.3) Administrator and operator logs

Aktivitas administrator dan operator sistem harus dicatat dan dilindungi.

Hasil scan: Tidak ada alert pada kategori ini.

(12.5.1) Installation of software on operational systems

Prosedur pengendalian instalasi software pada sistem operasional harus diterapkan.

Hasil scan: Tidak ada alert pada kategori ini.

D. Keamanan Komunikasi

(13.1.1) Security of network services

Mekanisme keamanan, tingkat layanan, dan persyaratan manajemen layanan jaringan harus diidentifikasi.

Hasil scan: Tidak ada alert pada kategori ini.

(13.2.1) Information transfer policies and procedures

Kebijakan dan prosedur transfer informasi formal harus diterapkan.

Hasil scan: Tidak ada alert pada kategori ini.

(13.2.3) Electronic messaging

Informasi dalam pesan elektronik harus dilindungi secara memadai.

Hasil scan: Tidak ada alert pada kategori ini.

E. Keamanan Pengembangan Sistem

(14.1.2) Securing application services on public networks

Informasi pada layanan aplikasi yang melewati jaringan publik harus dilindungi dari aktivitas fraud.

Hasil scan: Tidak ada alert pada kategori ini.

(14.1.3) Protecting application services transactions

Transaksi layanan aplikasi harus dilindungi dari transmisi tidak lengkap dan misrouting.

Hasil scan: Tidak ada alert pada kategori ini.

(14.2.1) Secure development policy

Aturan pengembangan software dan sistem harus ditetapkan dan diterapkan.

Hasil scan: Tidak ada alert pada kategori ini.

(14.3.1) Protection of test data

Data uji harus dipilih, dilindungi, dan dikendalikan secara cermat.

Hasil scan: Tidak ada alert pada kategori ini.

F. Ketersediaan

(17.2.1) Availability of information processing facilities

Fasilitas pemrosesan informasi harus memiliki redundansi sesuai kebutuhan ketersediaan.

Hasil scan: Tidak ada alert pada kategori ini.

G. Kepatuhan dan Privasi

(18.1.3) Protection of records

Rekaman harus dilindungi dari kehilangan, kerusakan, pemalsuan, dan akses tidak sah.

Hasil scan: Tidak ada alert pada kategori ini.

(18.1.4) Privacy and protection of personally identifiable information

Privasi dan perlindungan data pribadi harus dijamin sesuai regulasi yang berlaku.

Hasil scan: Tidak ada alert pada kategori ini.

(18.1.5) Regulation of cryptographic controls

Kontrol kriptografi harus digunakan sesuai perjanjian, perundangan, dan regulasi terkait.

Hasil scan: Tidak ada alert pada kategori ini.

4.3 Item yang Berhasil Dipindai (Coverage)

Selama sesi pemindaian, Acunetix hanya berhasil menjangkau 9 item/URL berikut:

- <https://id.quora.com/>
- <https://id.quora.com/cdn-cgi>
- <https://id.quora.com/cdn-cgi/challenge-platform>
- <https://id.quora.com/cdn-cgi/challenge-platform/h>
- <https://id.quora.com/cdn-cgi/challenge-platform/h/g>
- <https://id.quora.com/cdn-cgi/challenge-platform/h/g/orchestrate>
- https://id.quora.com/cdn-cgi/challenge-platform/h/g/orchestrate/chl_page
- https://id.quora.com/cdn-cgi/challenge-platform/h/g/orchestrate/chl_page/v1
- <https://id.quora.com/favicon.ico>

Sebagian besar item yang terjangkau merupakan jalur terkait Cloudflare Challenge Platform (cdn-cgi/challenge-platform), yang merupakan mekanisme proteksi bot/anti-scraping. Hal ini mengindikasikan bahwa crawler Acunetix kemungkinan besar terhambat oleh mekanisme proteksi tersebut sehingga tidak dapat menjelajah lebih dalam ke struktur aplikasi Quora.

4.4 Pembahasan

Hasil "Tidak ada alert" pada seluruh 27 klausul tidak dapat langsung diartikan sebagai kepatuhan penuh terhadap ISO/IEC 27001:2013, dengan pertimbangan sebagai berikut:

- Cakupan pemindaian sangat terbatas — hanya 9 item yang terjangkau dalam waktu 1 menit 9 detik, sebagian besar merupakan jalur proteksi Cloudflare, bukan halaman fungsional aplikasi Quora yang sesungguhnya.
- Acunetix bersifat pengujian teknis pada level aplikasi web (technical vulnerability scanning), sedangkan ISO/IEC 27001:2013 adalah standar sistem manajemen (management system standard) yang menilai kebijakan, prosedur, tata kelola risiko, serta aspek organisasi/administratif yang tidak dapat diuji melalui vulnerability scanner.
- Tidak ditemukannya alert pada suatu sesi scan tidak menjamin tidak adanya risiko keamanan sama sekali; kerentanan dapat saja tidak terdeteksi karena keterbatasan crawl, autentikasi yang tidak dilakukan, atau jenis pengujian yang tidak mencakup skenario tertentu.
- Untuk klaim kepatuhan ISO/IEC 27001:2013 yang valid, diperlukan audit menyeluruh oleh badan sertifikasi yang mencakup penilaian risiko, dokumentasi ISMS, serta bukti implementasi kontrol secara organisasi — bukan hanya hasil satu kali pemindaian otomatis.

BAB V — KESIMPULAN DAN SARAN

5.1 Kesimpulan

Berdasarkan hasil scan Acunetix terhadap target <https://id.quora.com/> pada tanggal 14 April 2026, tidak ditemukan alert kerentanan pada seluruh 27 klausul kontrol ISO/IEC 27001:2013 yang dipetakan dalam compliance report. Namun demikian, hasil ini lebih mencerminkan tidak ditemukannya kerentanan teknis yang eksplisit pada cakupan pemindaian yang sangat terbatas, bukan bukti kepatuhan penuh terhadap standar ISO/IEC 27001:2013 secara menyeluruh, mengingat keterbatasan crawl akibat proteksi Cloudflare dan sifat ISO 27001 sebagai standar manajemen yang tidak dapat dinilai sepenuhnya melalui pemindaian teknis semata.

5.2 Saran

- Melakukan pemindaian lanjutan dengan konfigurasi crawl yang lebih dalam dan/atau menggunakan autentikasi agar cakupan pengujian lebih representatif.
- Melengkapi asesmen teknis ini dengan audit manajerial (kebijakan keamanan informasi, SOP, dan manajemen risiko) untuk memperoleh gambaran kepatuhan ISO/IEC 27001:2013 yang lebih menyeluruh.
- Melakukan pemantauan keamanan secara berkala dan berkelanjutan, bukan hanya berdasarkan satu kali sesi pemindaian.

DAFTAR PUSTAKA

International Organization for Standardization. (2013). ISO/IEC 27001:2013 — Information technology — Security techniques — Information security management systems — Requirements.

Acunetix. (2026). International Standard - ISO 27001:2013 Compliance Report [Hasil pemindaian otomatis terhadap <https://id.quora.com/>, 14 April 2026].